SECCIÓN 7.2

# Tipos de herramientas y qué aporta cada una

**Temas de esta sección:**

- Ecosistema de herramientas en un SOC moderno
- Qué información aporta cada fuente y qué no suele mostrar
- Cuándo usar SIEM, EDR, XDR, SOAR, NDR, identidad, cloud, DLP, WAF y TI
- Herramientas de soporte: Threat Intel, Vulnerability Mgmt, ITSM/Ticketing
- Ejercicio: elegí la fuente correcta según el escenario

# 7.2 | Mapa práctico de herramientas principales

Cada fuente aporta una perspectiva distinta. Ninguna tiene el cuadro completo:

| Herramienta | Qué aporta | Qué no suele mostrar | Cuándo usarla |
|---|---|---|---|
| **SIEM** | Centraliza logs, correlaciones, búsquedas históricas y alertas multi-fuente. | *No siempre tiene detalle de endpoint o contexto de negocio.* | Búsqueda histórica, patrones, eventos de varias fuentes. |
| **EDR** | Procesos, parent process, command line, archivos, hashes, conexiones y acciones del endpoint. | *No siempre muestra correo, cloud o autorización del cambio.* | Ejecución, malware, LOLBins, persistencia o actividad en host. |
| **XDR** | Correlación entre endpoint, identidad, correo, red, cloud y alertas relacionadas. | *Puede abstraer demasiado y ocultar detalle crudo.* | Visión integrada de una cadena de ataque. |
| **SOAR** | Playbooks, automatización, orquestación, tickets, aprobaciones y acciones. | *No interpreta contexto complejo por sí solo.* | Procesos repetibles y coordinación de respuesta. |
| **NDR / IDS** | Tráfico, patrones de red, beaconing, anomalías, conexiones internas o externas. | *Puede no ver proceso o usuario exacto.* | C2, exfiltración, movimiento lateral, tráfico anómalo. |
| **IAM / Identity** | Logins, MFA, dispositivos, sesiones, tokens, permisos y riesgo de usuario. | *No siempre muestra actividad real dentro del endpoint.* | Compromiso de cuenta, OAuth, privilegios. |
| **WAF / App Logs** | Requests, payloads, respuestas HTTP, errores, endpoints, sesiones. | *No confirma ejecución en servidor sin logs/EDR.* | SQLi, command injection, web shell, abuso de API. |
| **DLP / CASB / Cloud** | Datos accedidos, descargas, uploads, sharing, apps cloud y exposición. | *No siempre identifica intención o endpoint comprometido.* | Exfiltración, uso de cloud apps, archivos sensibles. |

# 7.2 | Herramientas de soporte que también importan

## THREAT INTEL

Aporta reputación, contexto de campaña, TTPs, IOCs, relaciones entre dominios, IPs, hashes y actores.

Cuidado: la reputación puede estar desactualizada o ser ambigua en cloud compartido.

- Consultar siempre con fecha de actualización
- Combinar con evidencia técnica propia
- Un IOC sin contexto no confirma ataque

## VULNERABILITY MGMT

Aporta exposición, CVEs, criticidad, activos vulnerables, SLA de remediación y superficie expuesta.

Útil para decidir impacto y probabilidad de explotación.

- ¿El activo tiene CVE crítico sin parchear?
- ¿Está expuesto a internet?
- ¿Hay intentos de explotación activa?

## ITSM / TICKETING

Aporta contexto operativo: cambios aprobados, ventanas, responsables, tickets, tareas de mantenimiento y validaciones.

Clave para distinguir actividad autorizada de actividad sospechosa.

- ¿Existe CHG aprobado para esto?
- ¿El usuario está en el alcance?
- ¿La ventana coincide?

# 7.2 | Ejercicio: elegí la fuente correcta

Para cada escenario, elegí la primera fuente y las fuentes de apoyo:

| | | | |
|---|---|---|---|
| 1. Word ejecuta PowerShell codificado | → EDR + correo + DNS/proxy | 2. Login desde dispositivo desconocido | → IAM + cloud apps + correo |
| 3. Posible SQL Injection con HTTP 200 | → WAF + app logs + EDR servidor | 4. Subida de 6 GB a Dropbox | → DLP/CASB + proxy + identidad |
| 5. 40 hosts conectan al mismo dominio raro | → SIEM/NDR + DNS + endpoint | 6. Cuenta de servicio ejecuta vssadmin | → EDR + identidad + ITSM |
| 7. SOAR recomienda aislar un host | → SOAR + evidencia + criticidad | 8. Usuario recibió adjunto malicioso | → Email security + EDR + alcance |